

JUNIO 2026

THE BRIDGE
BOOTCAMPS



MARCO NORMATIVO

Versión	Fecha	Estado	Clasificación
1.0	Junio 2026	Aprobado	Interno



01 Propósito y alcance

Este documento forma parte del dossier de ciberseguridad del proyecto Aupa!. El objetivo del Marco Normativo es identificar el conjunto de regulaciones europeas y nacionales que aplican al proyecto, analizar el grado de cumplimiento actual frente a cada una de ellas y establecer las medidas necesarias para alcanzar la conformidad completa antes del lanzamiento.

El documento está redactado en formato de resumen ejecutivo (una ficha por norma) para facilitar su revisión por parte del equipo técnico, el tribunal evaluador y cualquier auditor externo.

Este Marco Normativo es un documento interno del dossier de ciberseguridad. Sin embargo, el cumplimiento del RGPD y la Directiva ePrivacy obliga a publicar dos documentos de acceso libre en la aplicación. Ambos se incluyen como anexos a este dossier y estarán accesibles desde el pie de página de Aupa:

Documento	Naturaleza	URL en la app	Obligación legal
Política de Privacidad	Público – lectura libre, sin registro	/privacidad	RGPD Art. 13 – información al interesado en el momento de recogida de datos
Política de Cookies	Público – lectura libre, sin registro	/cookies	Directiva ePrivacy / LSSI Art. 22 – consentimiento informado previo al uso de cookies no esenciales

02 Alcance

Este marco normativo cubre las tres regulaciones de aplicación directa o indirecta sobre Aupa en su versión actual (v1):

Norma	Ámbito de aplicación	Tipo de aplicación a Aupa
RGPD (UE) 2016/679	Tratamiento de datos personales de ciudadanos UE	Directa, obligatoria desde el primer usuario
NIS2 (UE) 2022/2555	Seguridad de redes e información en sectores críticos	Indirecta, vía cadena de suministro y proveedores
CRA (UE) 2024/2847	Productos con elementos digitales comercializados en la UE	Directa, la app es un producto digital Clase I

Quedan fuera del alcance de este documento las normativas sectoriales específicas de turismo, la fiscalidad aplicable y los contratos mercantiles con proveedores (aunque se referencian cuando son necesarios para el cumplimiento normativo).

03 Relación con otros documentos del dossier

Este Marco Normativo no es un documento aislado, ya que se apoya en y alimenta a otros entregables del proyecto. La siguiente tabla muestra las dependencias más relevantes:

Documento relacionado	Etapa	Relación con el Marco Normativo
Análisis MAGERIT	Etapa 1	El inventario de activos del MAGERIT es la base para identificar qué datos personales tratamos (RGPD) y qué componentes software documentar (CRA/SBOM).
Threat Model ATT&CK	Etapa 1	Los vectores de ataque identificados justifican las medidas técnicas exigidas por RGPD Art. 32 y NIS2 Art. 21.
Informe de hardening	Etapa 2	Las medidas de hardening implementan directamente los requisitos de seguridad técnica de RGPD y CRA.
Análisis OWASP Top 10	Etapa 2	Cubre las vulnerabilidades cuya explotación generaría una brecha de datos notificable bajo RGPD Art. 33.
Inventario + SBOM	Transversal	El SBOM es el mecanismo principal de cumplimiento del Art. 13 CRA (documentación de componentes).
SonarQube (SSDLC)	Transversal	El análisis estático automatizado da evidencia del desarrollo seguro exigido por CRA Art. 13.2.
Playbook de incidentes	Etapa 3	Incorpora los procedimientos de notificación a AEPD (RGPD 72h) y ENISA/CCN (NIS2 24h/72h).
BCP / DRP	Etapa 3	La continuidad de negocio cubre el requisito de resiliencia operativa de NIS2 Art. 21.

A continuación se presentan una ficha por cada una de las normativas aplicables a la aplicación:



RGPD - Reglamento General de Protección de Datos

Reglamento (UE) 2016/679

Aspecto	Detalle
Norma	Reglamento (UE) 2016/679 · Vigente desde mayo 2018
Ámbito	Toda app que trate datos personales de ciudadanos UE
¿Nos aplica?	Sí – recogemos correo, ubicación, preferencias y datos de uso
Autoridad	AEPD (España) · Multas hasta 20 M€ o 4 % facturación global

Bases legales utilizadas

La app se apoya en dos bases jurídicas del Art. 6 RGPD:

- Consentimiento explícito (Art. 6.1.a) – para cookies de análisis y marketing, creación de cuenta y comunicaciones opcionales.
- Ejecución de contrato (Art. 6.1.b) – para los datos necesarios para ofrecer el servicio (recomendaciones, guardado de favoritos).

Obligaciones clave y estado

Obligación	Cómo se implementa en la app	Estado
Política de privacidad (Art. 13)	Página /privacidad con información completa al registrarse	Cumple
Consentimiento cookies (ePrivacy)	Banner CMP antes de cualquier cookie no esencial	Cumple
Minimización de datos (Art. 5)	Solo campos obligatorios en registro; resto opcional	Cumple
Derecho de acceso / supresión (Art. 15-17)	Panel de usuario con exportación y borrado de cuenta	Parcial
DPO / Registro actividades (Art. 30)	Registro de tratamientos documentado internamente	Pendiente
Notificación brechas 72h (Art. 33)	Procedimiento DFIR incluye notificación a AEPD	Cumple

NIS2 - Directiva de Seguridad de Redes e Información

Directiva (UE) 2022/2555

Aspecto	Detalle
Norma	Directiva (UE) 2022/2555 · Transposición ES: pendiente de RD definitivo
Ámbito	Entidades esenciales e importantes en sectores críticos
¿Nos aplica?	Aplicación INDIRECTA – startup turismo no es entidad crítica, pero los proveedores cloud/SaaS que usamos sí lo son
Autoridad	Obliga a verificar y asegurar la cadena de suministro digital (Art.

Por qué nos importa NIS2 aunque no seamos entidad directa

NIS2 introduce la responsabilidad sobre la cadena de suministro (supply chain security). Aunque Aupa no es entidad esencial, los servicios que contratamos (hosting, DNS, CDN, APIs de pago) sí pueden serlo. Esto genera dos obligaciones prácticas:

- Due diligence de proveedores: verificar que AWS, Plausible, Stripe, Cloudflare, etc. cumplen NIS2 y tienen certificaciones equivalentes (ISO 27001, SOC 2).
- Cláusulas contractuales de seguridad: incluir requisitos mínimos de notificación de incidentes y medidas técnicas en contratos con proveedores críticos.

Medidas del Art. 21 NIS2 aplicadas a la app

Medida Art. 21	Implementación en el proyecto	Estado
Políticas de seguridad de la información	SSDLC documentado + política de desarrollo seguro	Cumple
Gestión de incidentes	Playbook incidentes (Etapa 3) + notificación en 24h	Cumple
Continuidad de negocio	BCP/DRP documentado (Etapa 3)	Cumple

Medida Art. 21	Implementación en el proyecto	Estado
Seguridad de la cadena de suministro	SBOM generado + revisión de dependencias con SonarQube	Cumple
Adquisición y desarrollo seguros (SSDLC)	SSDLC como marco transversal del proyecto	Cumple
Gestión de vulnerabilidades	Escaneo automático en pipeline CI/CD	Parcial
Criptografía y cifrado	TLS 1.3, bcrypt para contraseñas, cifrado en reposo	Cumple

Plazos de notificación de incidentes

- **< 24 horas:** alerta temprana al CSIRT / CCN-CERT si el incidente tiene impacto significativo.
- **< 72 horas:** notificación completa con evaluación preliminar.
- **< 1 mes:** informe final con causa raíz, medidas correctoras y lecciones aprendidas.

CRA – Cyber Resilience Act

Reglamento (UE) 2024/2847

Aspecto	Detalle
Norma	Reglamento (UE) 2024/2847 · En vigor octubre 2024 · Aplicación plena: octubre 2027
Ámbito	Productos con elementos digitales comercializados en la UE
¿Nos aplica?	SÍ – la app web es un producto digital con componentes software
Clasificación	Clase I (importante) – aplicación con gestión de cuentas de usuario
Autoridad	ENISA + autoridades nacionales · Multas hasta 15 M€ o 2.5 % facturación

SBOM: el núcleo del cumplimiento CRA

El Art. 13 CRA exige documentar todos los componentes software del producto. El SBOM (Software Bill of Materials) es la herramienta central para cumplir este requisito. Nuestro SBOM incluye:

- Inventario completo de dependencias directas e indirectas (npm, pip, Maven...).
- Versiones exactas, licencias y hash de integridad de cada componente.
- Historial de actualizaciones y registro de vulnerabilidades conocidas (CVE).
- Formato: CycloneDX 1.5 (recomendado por ENISA) generado automáticamente en el pipeline CI/CD.

Obligaciones CRA y estado del proyecto

Obligación CRA	Implementación	Estado
SBOM (Art. 13.1)	Generado con Syft en cada build · Formato CycloneDX 1.5	Cumple
Diseño seguro por defecto (Art. 13.2)	SSDLC + revisión de código en PRs + SonarQube	Cumple
Gestión de vulnerabilidades (Art. 13.6)	CVE tracking automatizado · Parches en < 24h para críticos	Parcial



Obligación CRA	Implementación	Estado
Notificación de vulnerabilidades explotadas (Art. 14)	Procedimiento hacia ENISA/CCN en < 24h	Pendiente
Periodo de soporte (Art. 13.8)	5 años mínimo o vida útil esperada del producto	Parcial
Documentación técnica (Anexo VII)	Arquitectura, threat model ATT&CK y análisis MAGERIT	Cumple
Marcado CE (Art. 28)	Necesario antes de comercialización en la UE · Octubre 2027	Pendiente

Relación SBOM con el resto del dossier

SBOM conecta con	Cómo
Análisis MAGERIT (Etapa 1)	Inventario de activos software = base del catálogo de riesgos
SonarQube (Transversal)	El análisis estático valida que las dependencias del SBOM no tienen CVE activos
Hardening (Etapa 2)	Las versiones del SBOM determinan qué parches aplicar
DFIR + Playbook (Etapa 3)	El SBOM permite identificar rápidamente qué componente está comprometido
BCP/DRP (Etapa 3)	El SBOM es parte del inventario de activos críticos para la recuperación

04 Resumen ejecutivo: análisis de brecha normativa

Estado consolidado de cumplimiento normativo del proyecto al cierre de la Etapa 2:

Norma	Cumple	Parcial	Pendiente	Prioridad
RGPD	4	1	1	Alta – datos personales desde día 1
NIS2 (indirecta)	5	1	0	Media – afecta a proveedores
CRA	3	2	2	Alta – aplicación plena en 2027

Próximos pasos prioritarios

- **RGPD:** completar el registro de actividades de tratamiento (Art. 30) y funcionalidad completa de ejercicio de derechos (portabilidad, oposición).
- **CRA:** establecer proceso formal de notificación de vulnerabilidades a ENISA y definir el periodo de soporte del producto.
- **CRA:** iniciar proceso de evaluación de conformidad para el Mercado CE (plazo límite: octubre 2027).

05 Anexos

A continuación se presentan la política de privacidad y la política de cookies. Ambos documentos son de acceso público en cumplimiento con la legislación actual y serán publicados tal y como están en la aplicación.

Política de Cookies

Última actualización: junio 2026

¿Qué son las cookies?

Las cookies son pequeños archivos de texto que se almacenan en tu dispositivo cuando visitas un sitio web o usas una aplicación. Sirven para recordar tus preferencias, analizar cómo usas el servicio y, en algunos casos, mostrarte contenido personalizado.

Esta política explica qué cookies utiliza Aupa!, para qué sirven cada una y cómo puedes gestionar tu consentimiento. Cumplimos con el RGPD (Reglamento UE 2016/679) y la Directiva ePrivacy transpuesta en el Art. 22 de la LSSI española.

El banner de cookies: qué verás al entrar

La primera vez que accedas a Aupa! (y cada vez que borres las cookies de tu navegador) verás un banner de consentimiento con el siguiente texto:



Aupa! utiliza cookies

Usamos cookies técnicas imprescindibles para que la app funcione. Si lo aceptas, también utilizaremos cookies de análisis (sin identificarte personalmente) para mejorar el servicio.

[[Aceptar todas](#)] [[Solo las necesarias](#)] [[Gestionar preferencias](#)]

[Más información en nuestra Política de Cookies.](#)

El botón «Cerrar» o la X no equivale a consentir. Solo se activan las cookies no esenciales si el usuario hace clic en «Aceptar todas» o las habilita manualmente en «Gestionar preferencias».

Cookies que utilizamos

A continuación encontrarás el inventario completo de cookies de Aupa, organizadas por categoría:



Cookies técnicas (siempre activas – no requieren consentimiento)

Nombre	Proveedor	Finalidad	Duración	Opt-in
session_id	Aupa (propio)	Mantener la sesión iniciada del usuario	Sesión (se borra al cerrar el navegador)	No
csrf_token	Aupa (propio)	Protección contra ataques CSRF	Sesión	No
lang_pref	Aupa (propio)	Recordar el idioma seleccionado por el usuario	12 meses	No
cookie_consent	Aupa (propio)	Guardar las preferencias de consentimiento de cookies	12 meses	No

Cookies de análisis (requieren consentimiento)

Nombre	Proveedor	Finalidad	Duración	Opt-in
_plausible	Plausible Analytics (UE)	Análítica de uso anónima y sin huella digital. No rastrea usuarios individuales ni utiliza fingerprinting.	Sin cookie persistente – datos agregados en servidor	Sí

Cookies de análisis (requieren consentimiento)

Nombre	Proveedor	Finalidad	Duración	Opt-in
map_pref	Aupa (propio)	Recordar el tipo de mapa preferido (satélite / mapa)	6 meses	Sí
filter_pref	Aupa (propio)	Guardar los filtros de búsqueda usados habitualmente	6 meses	Sí

Cookies de marketing o publicidad de terceros

Aupa no utiliza en la versión actual ninguna cookie de marketing, retargeting ni publicidad comportamental de terceros (Google Ads, Facebook Pixel, etc.). Si esto cambiara en versiones futuras, actualizaremos esta política y solicitaremos tu consentimiento explícito.



Cómo gestionar o retirar tu consentimiento

Puedes cambiar tus preferencias de cookies en cualquier momento de tres formas:

Desde la app: accede a Ajustes > Privacidad > Gestión de cookies. Los cambios surten efecto inmediatamente.

Desde el navegador: todos los navegadores modernos permiten configurar, bloquear o eliminar cookies. Aquí tienes los enlaces directos:

- Chrome: <chrome://settings/cookies>
- Firefox: Menú > Ajustes > Privacidad y seguridad > Cookies
- Safari: Preferencias > Privacidad > Gestión de datos del sitio web
- Edge: Configuración > Privacidad, búsqueda y servicios > Cookies

Por correo: escríbenos a privacidad@aupa.app con el asunto «Gestión de cookies».

Retirar el consentimiento no afecta a la licitud del tratamiento realizado con anterioridad. Las cookies técnicas no pueden desactivarse ya que son imprescindibles para el funcionamiento de la app.

Párrafo explicativo para la página /cookies

Este es el texto introductorio que aparecerá en la página de política de cookies, justo antes de las tablas detalladas:

– TEXTO PARA LA WEB (copiar tal cual) –

En Aupa creemos que tu privacidad es tan importante como encontrar el mejor pintxo del barrio. Por eso usamos las cookies estrictamente necesarias para que la app funcione, y solo añadimos las opcionales si tú nos lo permites.

Las cookies técnicas (sesión, seguridad e idioma) siempre están activas porque sin ellas la app directamente no funciona. Las de análisis nos ayudan a entender cómo se usa Aupa para mejorarla – pero usamos Plausible Analytics, una herramienta europea que no te identifica ni te rastrea entre sitios. Y las de personalización recuerdan tus preferencias de mapa y filtros para que no tengas que configurarlos cada vez.

Puedes cambiar tus preferencias cuando quieras desde Ajustes > Privacidad > Gestión de cookies. Si tienes cualquier duda, escríbenos a privacidad@aupa.app.

Actualización de esta política

Esta política puede actualizarse para reflejar cambios en las cookies que utilizamos o en la normativa aplicable. La fecha de la última actualización siempre aparece en la cabecera del documento. Te notificaremos los cambios relevantes mediante el banner de cookies o por correo electrónico.



Política de Privacidad

Última actualización: junio 2026

1. Responsable del tratamiento

En cumplimiento del Reglamento (UE) 2016/679 General de Protección de Datos (RGPD) y de la Ley Orgánica 3/2018 de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDGDD), te informamos de que el responsable del tratamiento de tus datos personales es:

Denominación social	Aupa App S.L. (en constitución)
CIF	[CIF pendiente de constitución]
Domicilio social	País Vasco, España
Correo de contacto	privacidad@aupa.app
Sitio web	https://aupa.app

2. Datos personales que tratamos

Aupa recoge únicamente los datos necesarios para prestarte el servicio. A continuación detallamos qué datos tratamos, con qué finalidad y bajo qué base jurídica:

Dato	Finalidad	Base jurídica (Art. 6 RGPD)	Conservación
Correo electrónico	Registro, login y comunicaciones de servicio	Ejecución de contrato (6.1.b)	Mientras la cuenta esté activa + 1 año
Nombre de usuario	Identificación en la plataforma	Ejecución de contrato (6.1.b)	Mientras la cuenta esté activa
Contraseña (hash bcrypt)	Autenticación segura	Ejecución de contrato (6.1.b)	Mientras la cuenta esté activa
Ubicación aproximada	Mostrar recomendaciones cercanas	Consentimiento (6.1.a)	Solo durante la sesión activa
Favoritos y valoraciones	Personalizar experiencia y mejorar recomendaciones	Ejecución de contrato (6.1.b)	Mientras la cuenta esté activa
Datos de uso y navegación	Análisis de producto (solo con consentimiento cookies)	Consentimiento (6.1.a)	13 meses desde la recogida
Dirección IP	Seguridad, detección de fraude y logs	Interés legítimo (6.1.f)	90 días en logs de servidor

Aupa no trata categorías especiales de datos (ideología, salud, origen racial, etc.) ni toma decisiones automatizadas con efectos jurídicos sobre los usuarios.



3. Menores de edad

Aupa está dirigida a mayores de 16 años. No recogemos conscientemente datos de menores. Si eres padre, madre o tutor y crees que un menor nos ha proporcionado datos personales, contáctanos en privacidad@aupa.app y procederemos a eliminarlos de inmediato.

4. Destinatarios y transferencias internacionales

Aupa no vende ni cede tus datos personales a terceros con fines comerciales. Únicamente compartimos datos con los proveedores estrictamente necesarios para la operación del servicio:

- Amazon Web Services (AWS) - infraestructura cloud. Región eu-west-1 (Irlanda). Sin transferencia fuera del EEE.
- Plausible Analytics - analítica web respetuosa con la privacidad, sin cookies de seguimiento y con datos anonimizados almacenados en la UE.
- Stripe - pasarela de pago (si se implementan funciones de pago en versiones futuras). Contrato de encargado de tratamiento firmado.

Todos nuestros proveedores han suscrito el correspondiente contrato de encargado del tratamiento (Art. 28 RGPD) y cumplen con las garantías adecuadas exigidas por el RGPD.

5. Tus derechos

Como titular de los datos tienes derecho a ejercer en cualquier momento los siguientes derechos, de forma gratuita y sin necesidad de justificación:

Derecho	Cómo ejercerlo	Plazo respuesta
Acceso (Art. 15)	Sección Mi cuenta > Mis datos	1 mes
Rectificación (Art. 16)	Sección Mi cuenta > Editar perfil	1 mes
Supresión / olvido (Art. 17)	Sección Mi cuenta > Eliminar cuenta	1 mes
Portabilidad (Art. 20)	Sección Mi cuenta > Exportar mis datos (JSON)	1 mes
Oposición (Art. 21)	Email: privacidad@aupa.app	1 mes
Limitación (Art. 18)	Email: privacidad@aupa.app	1 mes



Para ejercer cualquiera de estos derechos puedes acudir a la sección Mi cuenta de la app o enviarnos un correo a privacidad@aupa.app con el asunto «Ejercicio de derechos RGPD» adjuntando una copia de tu documento de identidad. Responderemos en un plazo máximo de un mes (prorrogable a tres en casos complejos).

Si consideras que no hemos atendido correctamente tu solicitud, tienes derecho a presentar una reclamación ante la Agencia Española de Protección de Datos (AEPD) en www.aepd.es.

6. Medidas de seguridad

Aupa! aplica medidas técnicas y organizativas apropiadas para proteger tus datos personales frente a accesos no autorizados, pérdida, alteración o destrucción accidental. Entre ellas:

- Cifrado de contraseñas con bcrypt (factor de coste 12).
- Comunicaciones cifradas con TLS 1.3 en todo momento.
- Cifrado en reposo de la base de datos.
- Acceso a datos de producción restringido a personal autorizado con autenticación multifactor.
- Revisiones de seguridad periódicas del código fuente mediante análisis estático (SonarQube).
- Plan de respuesta a incidentes con notificación a la AEPD en menos de 72 horas en caso de brecha de seguridad que afecte a tus datos (Art. 33 RGPD).

7. Cambios en esta política

Podemos actualizar esta Política de Privacidad para adaptarla a cambios normativos o en el servicio. Cuando lo hagamos, actualizaremos la fecha de la parte superior del documento. Si los cambios son sustanciales, te lo notificaremos por correo electrónico o mediante un aviso destacado en la app con al menos 15 días de antelación.



